

SportSlotReservation

Phase 5 Engineering Report — Admin & Onboarding

Field	Value
Scope	Platform-admin & tenant-admin surfaces; tenant onboarding; facility catalog; user provisioning; deletion lifecycle
Period	2026-06-14 to 2026-06-15 (sub-phases 5.1–5.6)
Author	Chandra Nakkalakunta — Principal Cloud & AI/ML Architect, Chandra AI Labs
Status	PHASE 5 COMPLETE — functional scope delivered; UI scalability & branding-in-dev deferred (tracked)
Tests	Backend 128 (92% coverage); frontend 43
ADRs	0014 Admin Architecture & Identity · 0015 Facility Catalog · 0016 User Provisioning · 0017 Deletion & Retention
Tenants validated	demo, rvrg, Honer Homes, Marina (isolation proven)

1. Executive Summary

Phase 5 turned SportSlot from a single-tenant booking app into a complete multi-tenant SaaS with full administrative onboarding. A platform administrator (superadmin) can create tenants and provision their first administrator. Each tenant administrator — after a mandatory first-login password change — configures facilities from a global catalog, sets branding and booking policies, and manages residents (single add, bulk CSV import, password reset, deactivation). Residents book within their tenant's isolated context. The flow was validated end-to-end across four real tenants, proving isolation.

The phase closed the longest-running architectural thread in the project: PlatformRepository, defined in Phase 2 with no runtime caller, received its first production use here. A uniform credential model (generate temporary password, force change on first login) governs every user-creation path through a single provisioning service, and a three-stage deletion lifecycle (active to inactive to purged) was designed with the purge foundation laid for Phase 7.

2. Key Decisions (ADRs 0014–0017)

ADR	Decision
0014 Admin Architecture	Admin surfaces as role-gated routes (not separate apps); first superadmin seeded (bootstrapping paradox); uniform generate-password + force-change credential model; route+role gating in dev, host-segregation deferred to Phase 9
0015 Facility Catalog	Two layers: a global facility-type catalog (seeded) and per-tenant named instances; tenant admin selects a type and configures named courts; free-form sport creation removed
0016 User Provisioning	A single UserProvisioningService is the only user-creation path (generate password, Firebase user + claims, profile, compensating-delete rollback, audit); CSV bulk import with per-row results, 500-row cap; synchronous in the main API now, background job in Phase 7
0017 Deletion & Retention	Three-stage lifecycle active to inactive to purged; soft delete disables auth + auto-cancels future bookings; authority matrix (tenant-admin in own tenant, superadmin anywhere); retention purge deferred to Phase 7 with deactivated_at written now

3. Issue Log — the instructive part

#	Symptom / root cause	Rule adopted
1	Superadmin 403 everywhere — ADR-0007 strict host-gating in code contradicted ADR-0014's route+role relaxation	When a new ADR modifies an earlier one, note supersession in both and grep the code for the old rule
2	Non-demo tenant admins 403 on localhost — a dev-tenant pin forced all local auth to one tenant	Multi-tenant bugs hide until the SECOND instance; the first matches every default. Test with two, early
3	create-user 500 in cloud, worked locally — deployed SA lacked Firebase Auth permission (least privilege); dev impersonates a broader SA	The deployed runtime SA is less privileged than dev creds by design; verify the runtime SA's roles, not dev's
4	Forced password change skipped, then looped — flag checked only in one route; then stale cache bounced post-change	A security gate must be a single unbyypassable choke point (in the route guards), not a per-route check
5	VALIDATION_FAILED hid which field failed	Make errors loud in dev — surface field detail; opacity costs round-trips
6	Branding theme wrong for tenant admins in dev (no subdomains)	Some bugs are environment limitations; stop fixing in the wrong environment, fix when the environment is right (Phase 7 subdomains)

4. Under-Specified Requirements Caught Mid-Flight

Several requirements were absent from the original plan and surfaced only because the design was questioned during the build: the entire deletion/retention lifecycle (a core CRUD verb), a branding logo, the inapplicability of a flat number to administrators, admin-initiated password reset, facility-catalog management, and multi-tenant

administrators. The lesson, recorded for future projects: enumerate every entity's full lifecycle (including delete and retain) and the full actor matrix (who can do each action, across tenant boundaries) at design time. The verbs and actors omitted at planning are precisely the ones that became mid-flight decisions.

5. Validation Quality

Every defect that mattered — the tenant 403s, the cloud provisioning 500, the bypassable password gate — was found by exercising the system as a real user across multiple tenants, not by the automated suite, which remained green throughout. Green tests proved necessary but not sufficient. The disciplined response — one decisive API or log observation per symptom before proposing a fix — repeatedly converted a daunting cluster of symptoms into a short, precise, fixable list, and twice revealed that an apparent bug was a stale deployment or an environment limitation rather than broken code.

6. Deferrals (tracked)

Item	Target
UI scalability & UX optimization (table/pagination/search/filter, shared list component, admin-resident segregation, superadmin tenant-user-management UI, natural ordering)	Dedicated phase, post functional-completion
Multi-tenant branding correctness in dev	Phase 7 (real subdomains)
Per-sport quota (currently per-day-total) + composite index	Booking-core sub-phase
Multi-interval / selectable facility hours	Own sub-phase (amends ADR-0010/0015)
Multi-tenant admin (one admin to many tenants)	Phase 8+ (auth-model change, needs ADR)
Self-service email password reset	Phase 7 (notifications)
Facility-catalog management UI; GCS logo upload	When needed / own sub-phase

7. Next — Phase 6: CI/CD

Phase 5 was deployed through manual, ordered make commands, and several debugging detours this phase traced to deployment ambiguity (is the backend current? the frontend? the right service account?). Phase 6 addresses this directly: GitHub Actions authenticating via Workload Identity Federation — no service-account keys, extending the charter's zero-static-credentials rule to CI — running the gate suite and deploying both surfaces on push to main. This makes 'committed' and 'deployed' the same event, eliminating the stale-image and skipped-step failure modes encountered repeatedly during manual operation.